

SECURITY OPERATIONS CENTER · HOME LAB

Phase 4

Dual-Firewall Network & a Site-to-Site VPN

Two sites joined by an encrypted tunnel — and the question it forces: [what can you detect when you can't read the traffic?](#)

A theory overview of what this phase built, why, and what we learned. The hands-on build is the companion video.

What Phase 4 does

- Add a **second site** — a branch office behind its own firewall.
- Join the two sites with an **encrypted IPsec VPN** across an untrusted transit.
- Carry the branch's traffic to the **central SOC** — a realistic "remote office reporting home."
- Attack from **inside the branch** and from **on the transit wire**, and see where the SOC can still detect it.

*The through-line: **P1** can we see? · **P2** across a router? · **P3** once a firewall lies? · **P4** once the traffic is encrypted?*

A routed link vs an encrypted VPN

A routed link BEFORE

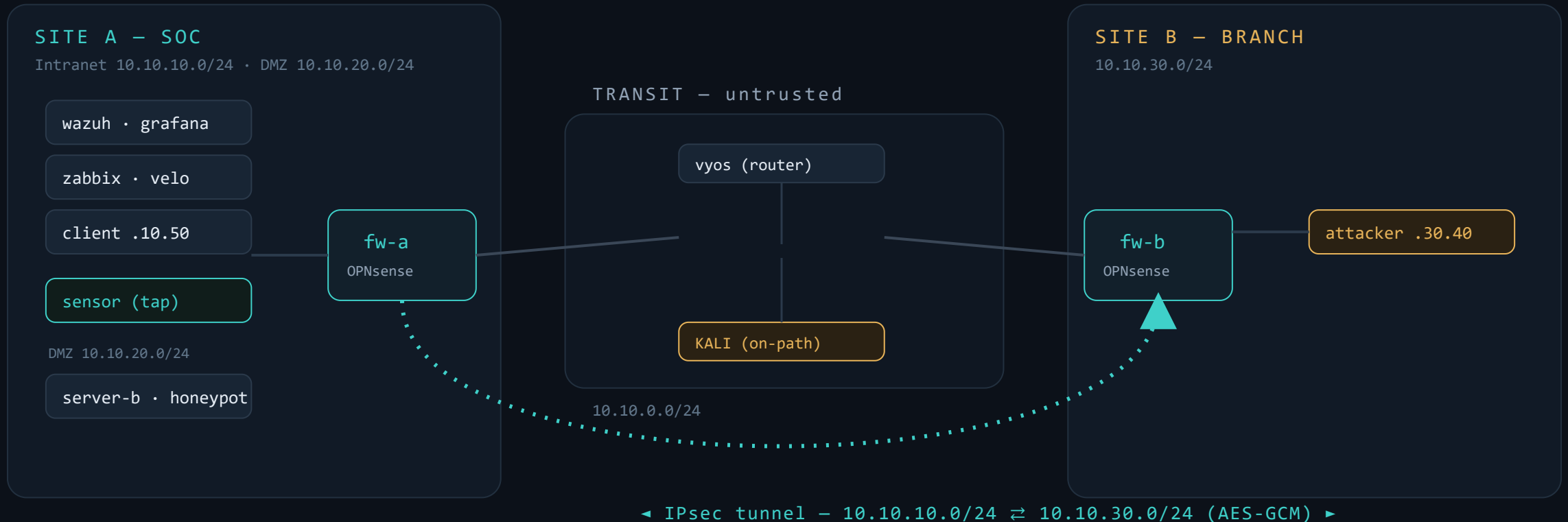
Moves packets between networks. Anyone on the path can **read** every packet — ports, flags, payload — all in the clear. Your sensor sees the traffic directly.

A VPN tunnel PHASE 4

Wraps each packet inside an encrypted one. Anyone on the path sees only an **ESP** blob between two firewalls. Ports, flags, payload — sealed inside.

*A VPN is a routed link that first **seals** every packet — protecting it from the wire, and hiding it from your own defenders.*

Site A ↔ Transit ↔ Site B



The tunnel is the **only path** a branch host takes to reach the SOC — it crosses the untrusted transit sealed.

The IP table

SITE A – SOC	ROLE	IP	TRANSIT & SITE B	ROLE	IP
fw-a	LAN / DMZ / WAN	.10.1 / .20.1 / .0.1	fw-a WAN	tunnel endpoint A	10.10.0.1
wazuh	SIEM manager	10.10.10.20	fw-b WAN	tunnel endpoint B	10.10.0.2
grafana	dashboards	10.10.10.24	vyos	transit router	10.10.0.x
zabbix · velo	avail. · forensic	.22 · .23	KALI	on-path attacker	10.10.0.x
client	internal host	10.10.10.50	fw-b	branch firewall	10.10.30.1
sensor	Suricata/Zeek tap	tap · 56.10	attacker	branch attacker	10.10.30.40

Tunnel: **IKEv2 · pre-shared key · AES-GCM**, joining **10.10.10.0/24 ⇌ 10.10.30.0/24**. Management is out-of-band on **192.168.56.0/24**.

What builds Phase 4

Two firewalls — OPNsense

fw-a at the SOC, **fw-b** at the branch. Stateful firewalls; each terminates the tunnel and enforces its site's policy.

The tunnel — IPsec / strongSwan

IKEv2 key exchange, AES-GCM encryption (ESP), pre-shared-key authentication.

The transit — VyOS

A router playing "the internet" — the untrusted segment the tunnel must cross.

Detection & tools

Suricata + Zeek sensor, Wazuh, Grafana — plus **nmap** and **Nikto** as the attacker's toolkit.

*One new idea, three new parts: a **second firewall**, an **untrusted transit**, and an **encrypted tunnel** between them.*

IKE agrees the keys; ESP carries the traffic

- **IKE (the handshake)** — the two firewalls authenticate with a pre-shared key and agree secret keys. Done once, refreshed on a timer.
- **ESP (the payload)** — every real packet is encrypted with those keys and wrapped as ESP. This is the continuous data flow.
- **Tunnel mode** — the whole original packet is sealed; only the firewall-to-firewall header shows.

```
local  10.10.0.1 ↔ remote 10.10.0.2
auth   pre-shared key (both ends)
proto  IKEv2 · AES-GCM · SHA-256
tunnel 10.10.10.0/24 ⇄ 10.10.30.0/24
state  ESTABLISHED · INSTALLED
```

Both ends must agree on **identity, key, and the exact pair of networks** — and note ESP is a protocol (50), not a port, so the firewall must permit it.

Encryption hides the attack from everyone — **including your defenders.**

A signature engine matches **ports, flags, and payloads**. Inside the tunnel there are none to read — only an opaque **ESP** blob between two firewalls.

So how do you catch an attacker
you **cannot read?**

This is the problem Phase 4 exists to solve.

Two places to watch — opposite visibility

On the transit THE MIDDLE

Only **ESP**. No ports, no flags, no payload. Content inspection is dead — you're left with **traffic analysis**: timing, size, regularity. You learn **that** something happened, not what.

At the decryption point INSIDE THE SITE

Once fw-a decrypts, the packets are in the clear again. Signatures work; the sensor reads the **whole attack** and names the **real source** — inter-site tunnel traffic isn't NAT'd, so attribution survives.

*Blindness lives only **in the tunnel**. Detection moves to where the firewall hands the traffic back in the clear.*

Two attackers, two lessons

Attacker in Branch B

.30.40

Rides the trusted VPN into the SOC. Decrypted at HQ, so it **is** detectable — with the real branch IP named.

Proves a VPN doesn't vet a threat coming from a trusted branch.

Attacker on the transit

KALI

Sits on the wire between the sites and scans the tunnel — and sees only **ESP**.

Proves the VPN's confidentiality holds — the man-in-the-middle is blind.

*One attacker tests **what the VPN lets through**; the other tests **what the VPN hides**.*

The branch attacks — caught at the decryption point

nmap scan:

```
10.10.30.40 -> 10.10.10.50 | LOCAL NMAP SYN scan (window 1024)
10.10.30.40 -> 10.10.10.50 | LOCAL NMAP TCP connect/version sweep
```

Nikto web scan:

```
6x LAB LFI attempt - /etc/passwd requested in URL ← our custom rule
1x ET WEB_SPECIFIC_APPS Wordpress LiteSpeed CVE-2024-44000
```

- Both attacks rode the tunnel, were **decrypted at fw-a**, and lit up the Site A sensor.
- Every alert names the **real attacker 10.10.30.40** — attribution survives the VPN.

A signature written two phases ago (LFI) caught a real scanner arriving encrypted, once the traffic was in the clear.

The same attack, blind on the transit

Captured on the transit during the exact same scan:

```
10.10.0.2 > 10.10.0.1: ESP(spi=0xc545f539), length 80
10.10.0.1 > 10.10.0.2: ESP(spi=0xcd60626c), length 76
10.10.0.2 > 10.10.0.1: ESP(spi=0xc545f539), length 80  ...
```

- No ports. No flags. No `10.10.30.40`. No scan pattern. **Only encrypted ESP** between two firewalls.
- The on-path attacker sees **that** the firewalls are talking — when, and how much — and nothing else.

This is the confidentiality of the VPN, proven from the attacker's own seat on the wire.

Two half-truths, aligned, name the attacker

WITNESS	WHAT IT SAW AT TIME T	VALUE
Transit (on-path)	encrypted surge, fw-b $\rightleftharpoons$ fw-a	when + how much
Site A sensor	.30.40 scanned .10.50	who + what

Neither alone tells the story. Align them by **timestamp** and the encrypted surge on the wire **is** the scan the sensor decoded — the branch attacker, hidden inside the tunnel, is unmasked.

Once traffic is encrypted, no single log is authoritative — **correlation across the boundary is the skill the phase teaches.**

PHASE 4 · DUAL-FIREWALL + VPN

PASSED

Two sites joined by an encrypted tunnel. An attacker in a trusted branch, caught and named at the decryption point. The same attack, blind on the wire — and unmasked by correlating the two views.

**Encryption blinds the middle; the
decryption point restores sight;
correlation names the attacker.**

Next: the **practical video** — building the tunnel and running these attacks live.